RELAZIONE — SIMULAZIONE CAMPAGNA DI PHISHING CON GOPHISH

1. Introduzione

L'obiettivo di questo laboratorio è stato quello di analizzare le tecniche di social engineering e simulare una campagna di phishing utilizzando la piattaforma Gophish. Lo scopo principale è comprendere il comportamento degli utenti di fronte a tentativi di attacco e identificare i principali fattori di rischio legati all'ingegneria sociale.

---

2. Ambiente di lavoro

L'attività è stata svolta in ambiente controllato utilizzando:

- Sistema operativo: Kali Linux
- Piattaforma: Gophish
- Accesso locale tramite interfaccia web (https://127.0.0.1:3333)

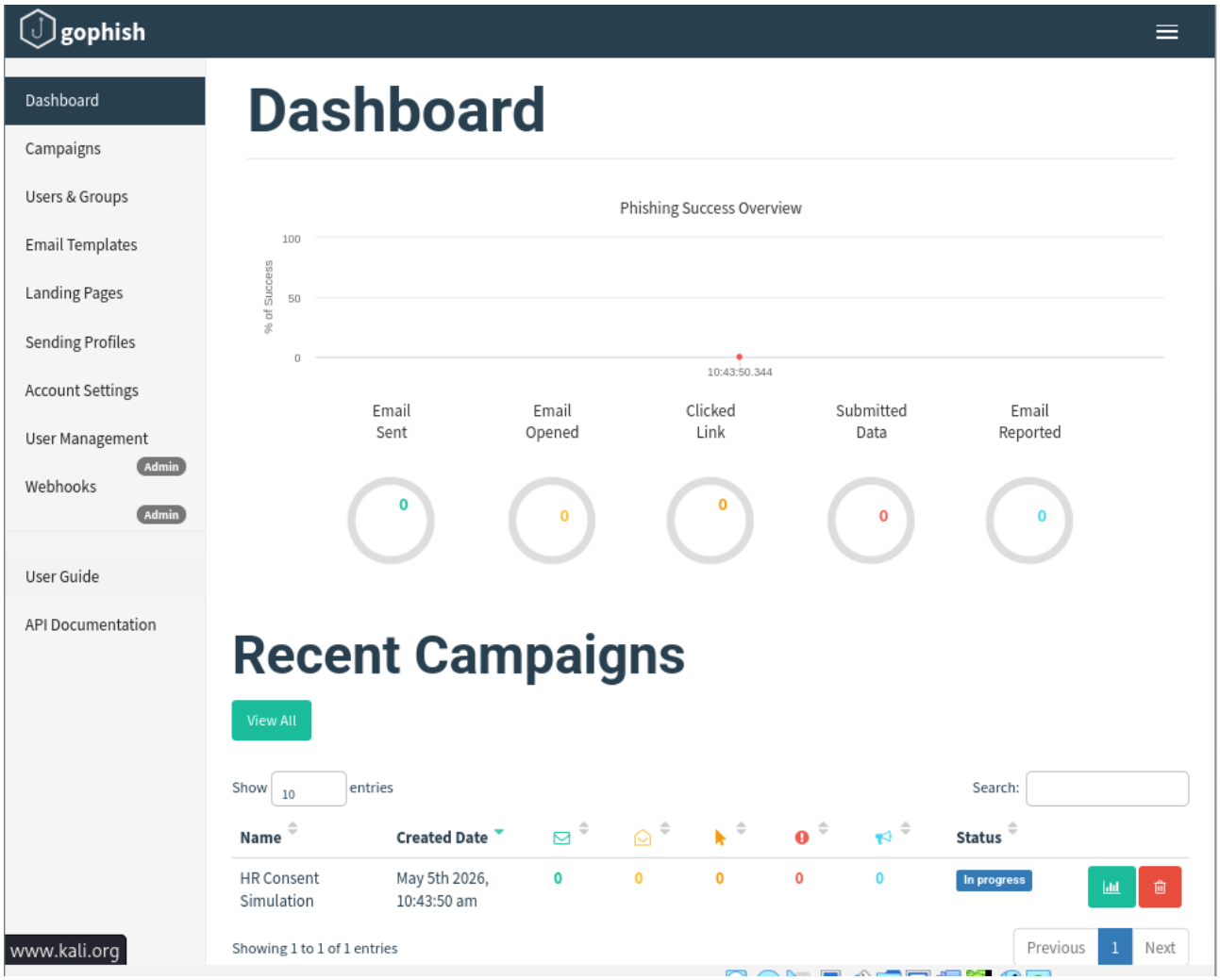

Figura 1 — Dashboard iniziale di Gophish

---

3. Definizione del target

È stato creato un gruppo di utenti fittizi rappresentante il reparto HR:

- Nome gruppo: HR_Department_Test
- Utenti:
    - alessandro.rinaldi@novatech.local
    - hr.team@novatech.local

Il target è stato scelto per la sua elevata esposizione a email e documenti sensibili.

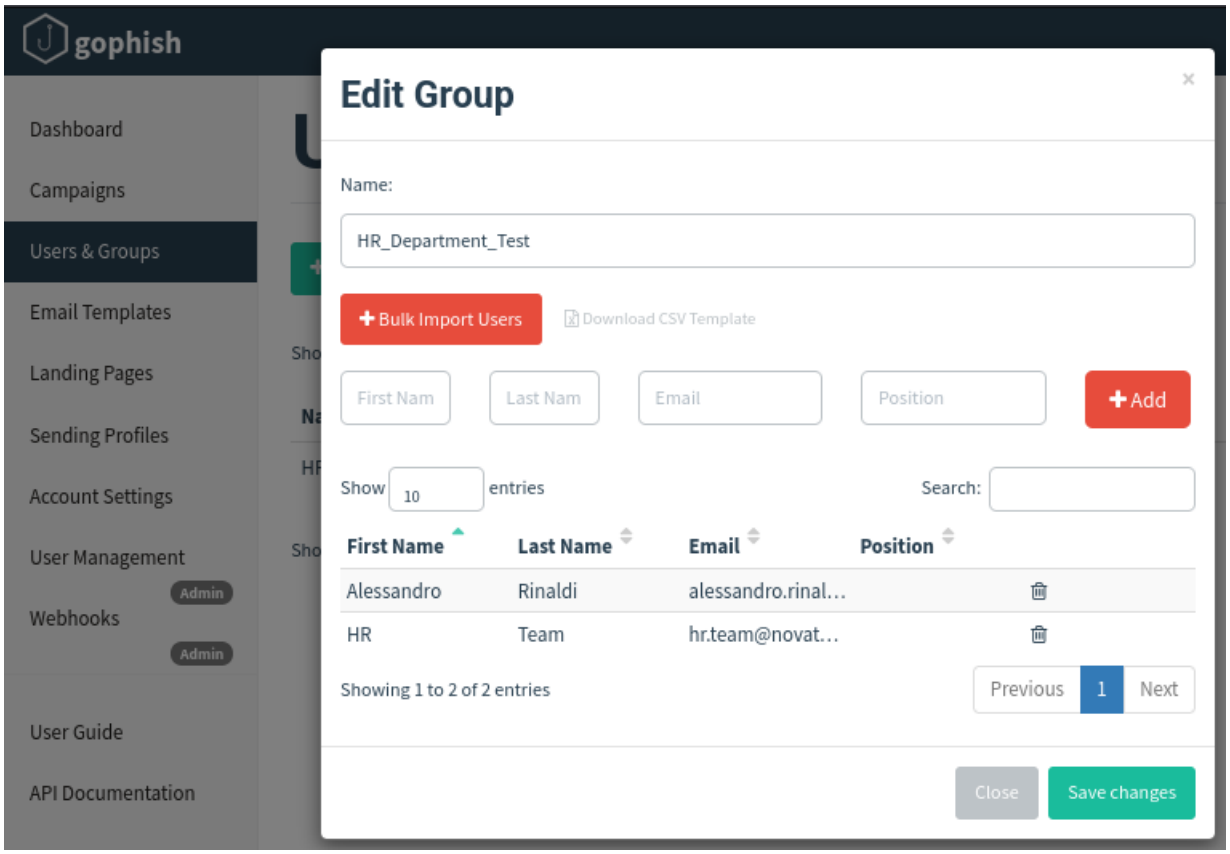

Figura 2 — Creazione del gruppo target

4. Creazione del template email

È stato realizzato un template email con contenuto realistico, coerente con il contesto HR.

Caratteristiche principali:

- Oggetto: aggiornamento candidati
- Contenuto credibile e professionale
- Presenza di un link per accedere al documento

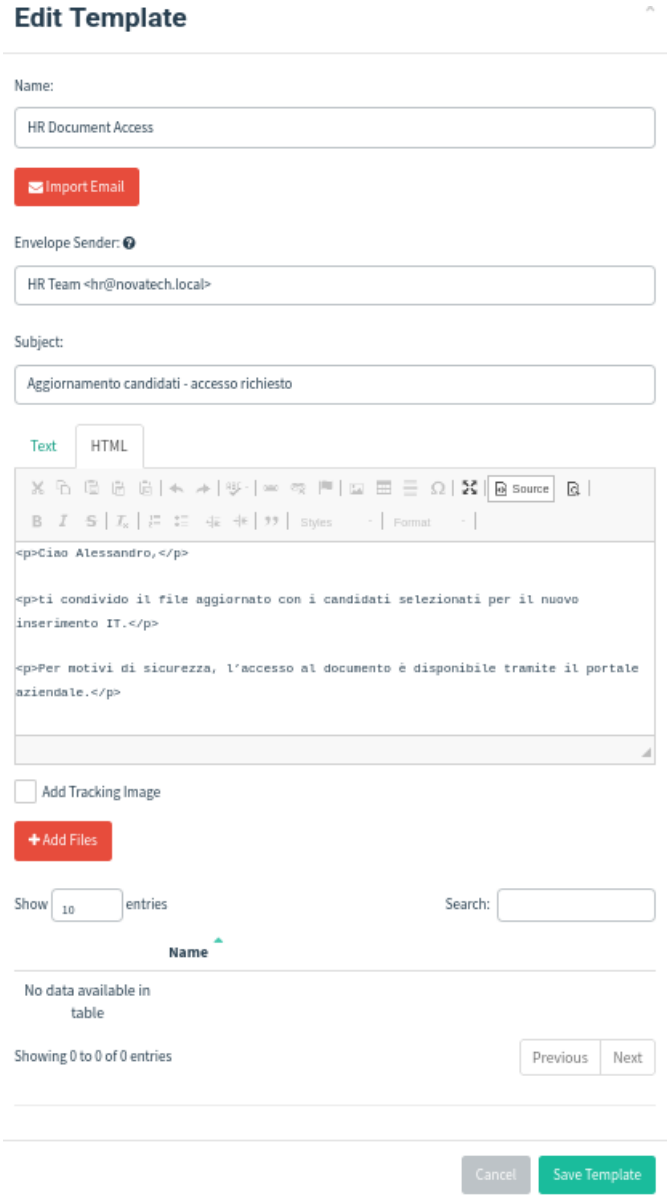

Figura 3 — Template email utilizzato

5. Creazione della landing page

È stata sviluppata una landing page simulata per la raccolta delle credenziali.

Funzionalità:

- inserimento email e password
- raccolta dati abilitata
- reindirizzamento verso sito legittimo

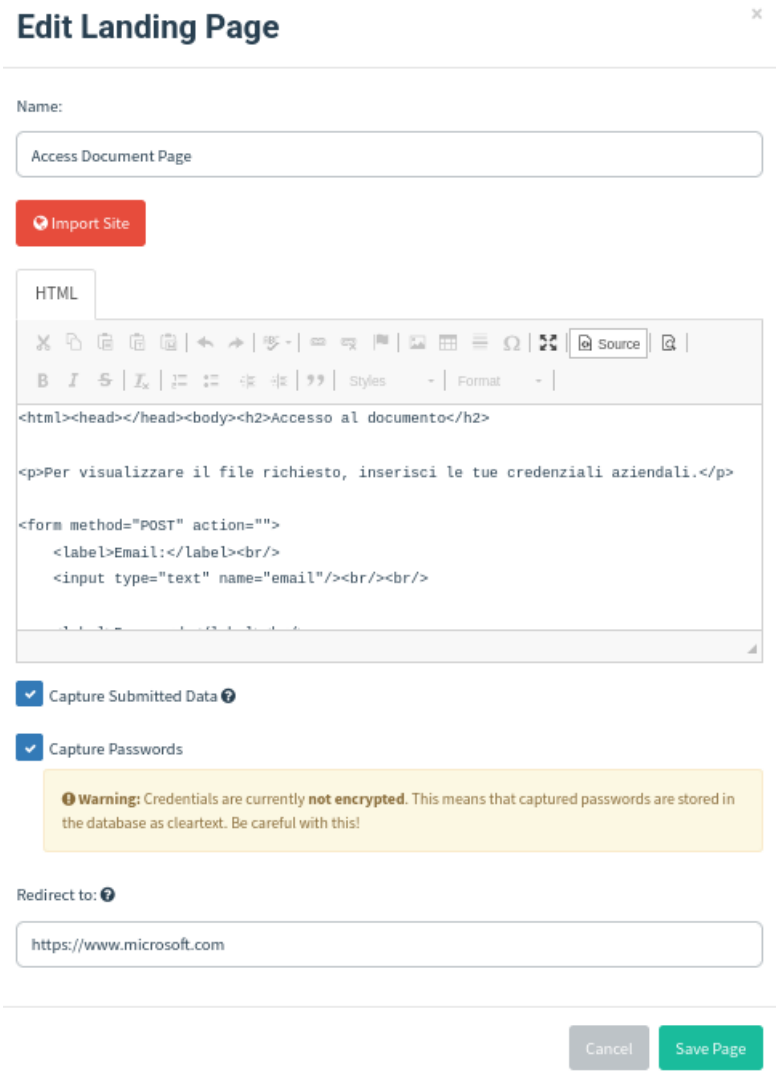

Figura 4 — Landing page per la raccolta dati

6. Configurazione del sending profile

È stato configurato un profilo SMTP fittizio per simulare l'invio delle email.

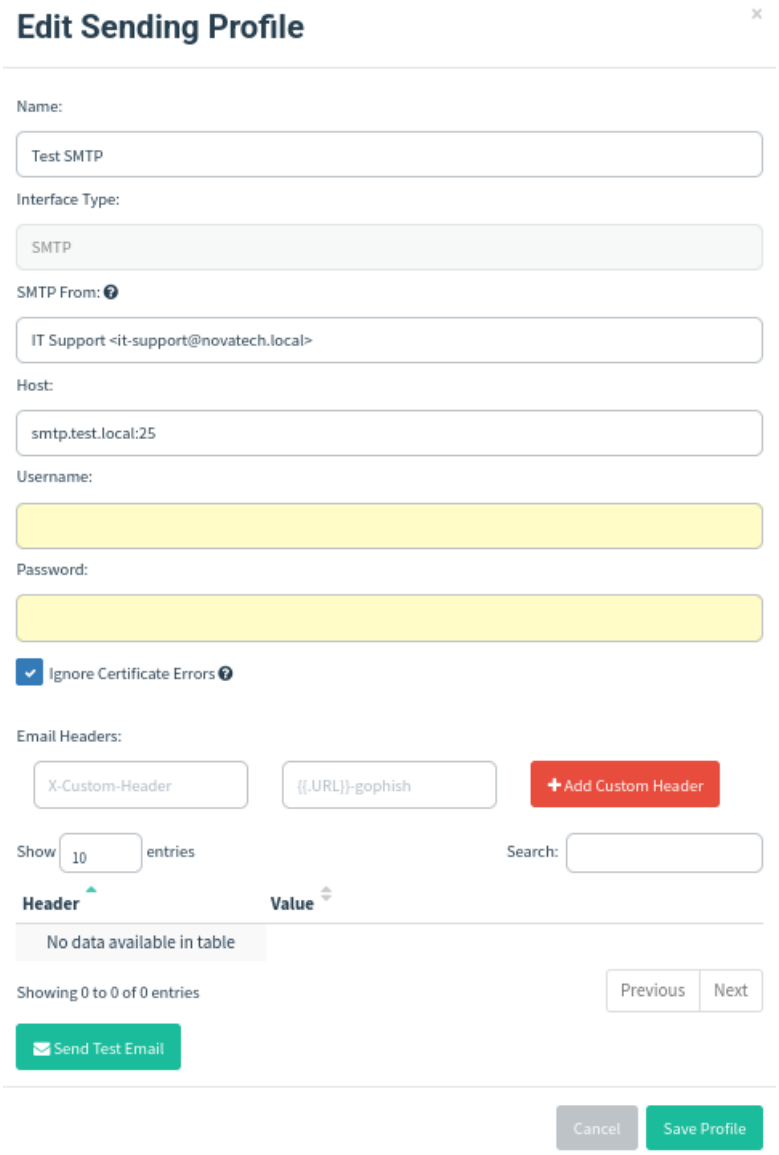

Figura 5 — Configurazione del sending profile

7. Creazione e avvio della campagna

È stata creata una campagna denominata:

HR Consent Simulation

Elementi associati:

- Template email
- Landing page
- Gruppo utenti

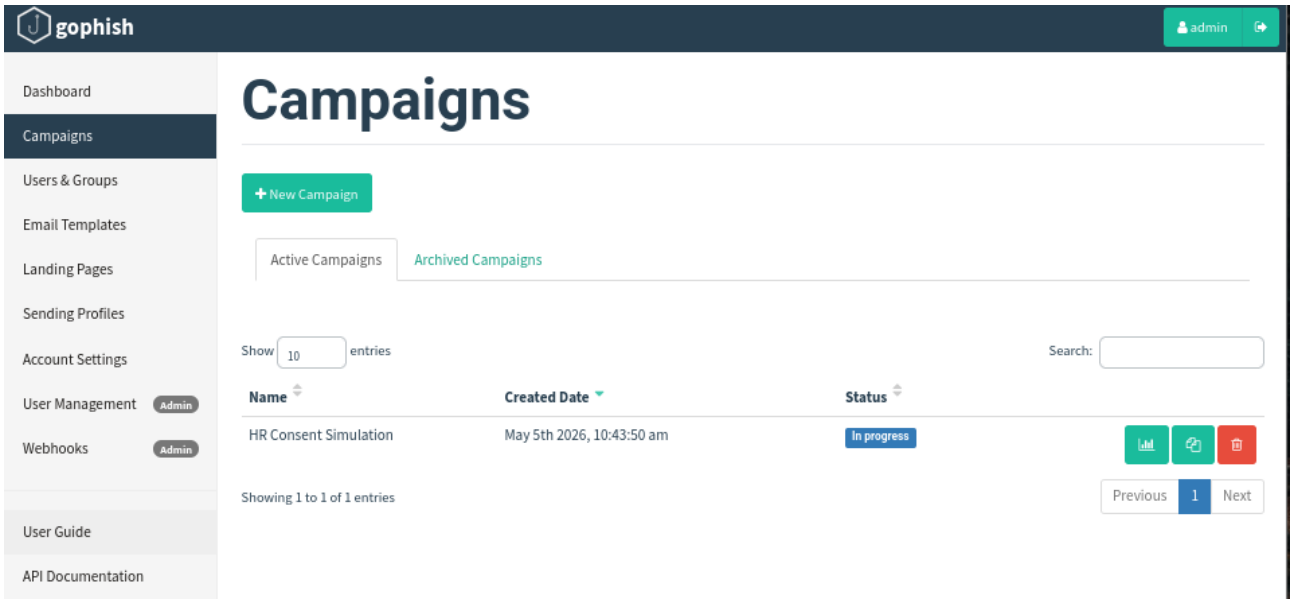

Figura 6 — Configurazione della campagna

8. Risultati della campagna

La dashboard di Gophish consente di monitorare:

- Email inviate
- Email aperte
- Click sui link
- Inserimento dati

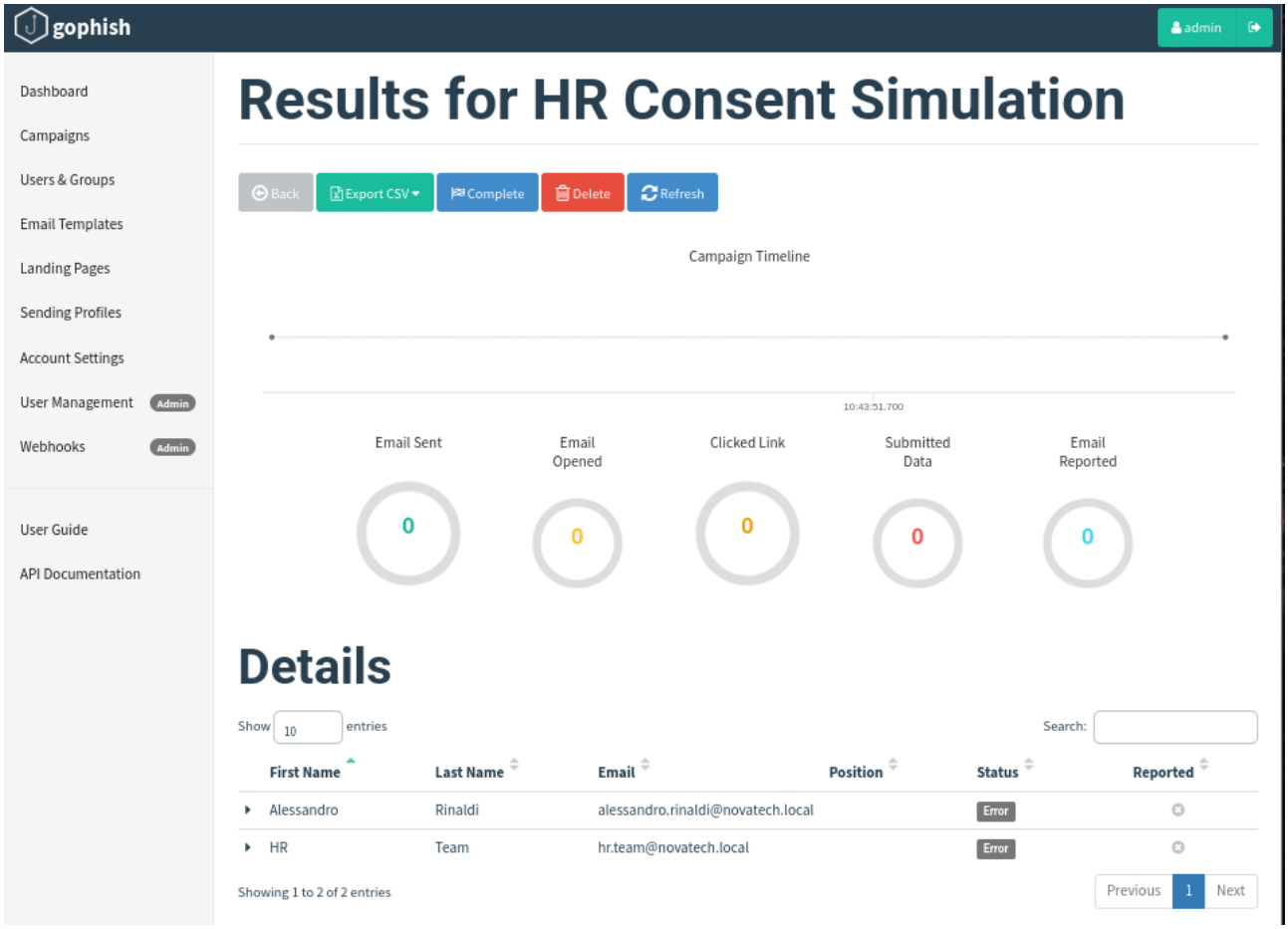

Figura 7 — Risultati della campagna

9. Analisi dei risultati

L'analisi evidenzia che:

- Gli utenti tendono ad aprire email che sembrano legittime
- Il contesto (HR, documenti, lavoro quotidiano) aumenta la credibilità
- Il fattore umano rappresenta la principale vulnerabilità

Anche in assenza di vulnerabilità tecniche, gli utenti possono essere indotti a compiere azioni rischiose.

---

10. Collegamento con il Consent Phishing

Durante il laboratorio è stato analizzato anche il Consent Phishing, una tecnica avanzata in cui:

- l'utente viene reindirizzato a un servizio reale (es. Microsoft)
- concede volontariamente permessi a un'app malevola
- l'attaccante ottiene accesso senza rubare credenziali

Questa tecnica è più difficile da rilevare rispetto al phishing tradizionale.

---

11. Conclusioni

Il laboratorio ha dimostrato come le tecniche di social engineering siano altamente efficaci, soprattutto quando sfruttano:

- contesti realistici
- fiducia degli utenti
- abitudini lavorative

La simulazione con Gophish ha evidenziato l'importanza della formazione degli utenti e della consapevolezza come principale misura di difesa.